

Informe Técnico de Documentación Oficial

Historias de Usuario: HU-RBAC-001 y HU-RBAC-004 · Sprint 1

Proyecto: The Nexus Battles VI (Monorepo)	Módulo: Cuentas, Cumplimiento y Comercio (Grupo 4)
Responsable Técnico: Andrés Núñez (AN)	Microservicio: services/cuentas/ms-identidad (Java 21, Spring Boot 4.1.1)
Base de Datos: PostgreSQL 16 (puerto 5433, db-ms-identidad)	Frontend: JavaScript ES2022 Vanilla (sin frameworks)
Ramas de Git: feat/hub-cuentas-e2e / feature/HU-RBAC-001-004	Estado de la Suite: 99 pruebas automatizadas pasando (100%)

1. HU-RBAC-001: Modelo y Matriz de Permisos por Rol

Objetivo: Implementar el modelo formal de Control de Acceso Basado en Roles (RBAC) para gobernar las capacidades de cada cuenta en el sistema. La interfaz gráfica oculta en el DOM de forma reactiva las acciones no autorizadas, mientras que el microservicio ms-identidad actúa como autoridad única e inmutable de evaluación bajo el principio de Mínimo Privilegio.

Criterio Oficial	Estado	Evidencia de Cumplimiento
CA-1: 4 Roles y Mínimo Privilegio Jugador, Moderador, Administrador, Super Admin. Rol desconocido recibe mínimo privilegio.	CUMPLIDO	Role.java, RolEntity.java, RolSeeder.java. Todo rol desconocido cae en Default-Deny estricto.
CA-2: Matriz Canónica con Acción Temporal Sigue la Tabla 24 extendida. Moderador tiene permiso TEMPORARY en suspender usuarios.	CUMPLIDO	RbacMatrixRepository.java y matriz-rbac.js. Moderador tiene explícitamente TEMPORARY en SUSPENDER_USUARIOS.
CA-3: Default-Deny y Alerta de Inconsistencia Toda tupla no contemplada se deniega. Discrepancias generan registro de alerta.	CUMPLIDO	RbacAuthorizationService.java: emite RBAC_INCONSISTENCY_DETECTED ante valores nulos y deniega.
CA-4: Directiva Reactiva de Frontend La UI oculta o deshabilita acciones administrativas no permitidas en tiempo real.	CUMPLIDO	Directiva has-permission en has-permission.directive.js oculta del DOM con display: none.

Matriz Oficial de Autorización (12 Acciones × 4 Roles = 48 Combinaciones)

#	Acción de Plataforma	Jugador	Moderador	Administrador	Super Admin
1	CREAR_CUENTA_JUGADOR	GRANTED	DENIED	DENIED	DENIED
2	MODIFICAR_PERFIL_PROPIO	GRANTED	GRANTED	GRANTED	GRANTED
3	PUBLICAR_COMENTARIOS	GRANTED	GRANTED	GRANTED	GRANTED
4	ELIMINAR_COMENTARIO_PROPIO	GRANTED	GRANTED	GRANTED	GRANTED
5	MODERAR_COMENTARIOS	DENIED	GRANTED	GRANTED	GRANTED
6	EMITIR_ADVERTENCIAS	DENIED	GRANTED	GRANTED	GRANTED
7	SUSPENDER_USUARIOS	DENIED	TEMPORARY	GRANTED	GRANTED
8	BANEAR_DEFINITIVAMENTE	DENIED	DENIED	GRANTED	GRANTED
9	CREAR_ADMIN_MODERADOR	DENIED	DENIED	DENIED	GRANTED
10	GESTIONAR_PRODUCTOS	DENIED	DENIED	GRANTED	GRANTED
11	ASIGNAR_ROL	DENIED	DENIED	DENIED	GRANTED
12	GESTIONAR_CUENTAS	DENIED	DENIED	GRANTED	GRANTED
Total	Acciones Autorizadas	4 / 12	7 / 12	10 / 12	11 / 12

Argumento de Oro para la Sustentación: El Super Administrador tiene 11/12 acciones y NO 12/12. La acción CREAR_CUENTA_JUGADOR es un auto-registro público. Concedérsela a un Super Administrador violaría el principio de Mínimo Privilegio. Esto evidencia que el sistema aplica **Default-Deny real** y no jerarquía ciega.

2. HU-RBAC-004: Verificación de Autorización Server-Side y Fail-Closed

Objetivo: Garantizar que la seguridad **nunca dependa del cliente**. Toda petición hacia endpoints administrativos es interceptada en el servidor por SecurityInterceptor, validando criptográficamente la firma del Bearer JWT y el claim de versión (ver). Ante cualquier discrepancia, anomalía o caída de servicio, el microservicio responde de inmediato bajo la política **Fail-Closed** devolviendo 403 Forbidden en formato RFC 7807 UTF-8 y emitiendo auditoría asíncrona.

Criterio Oficial	Estado	Evidencia de Cumplimiento
CA-1: Verificación de Credencial y Permiso Valida credencial de sesión y permiso antes de ejecutar la lógica de negocio.	CUMPLIDO	Anotación @RequirePermission y SecurityInterceptor.java validando Bearer JWT (HMAC-SHA256).
CA-2: Política Fail-Closed Si el servicio de autorización falla o no está disponible, se deniega incondicionalmente.	CUMPLIDO	Cualquier token nulo, expirado o rol insuficiente aborta el pipeline y retorna 403 Forbidden.
CA-3: Registro Obligatorio de Intentos No Autorizados Todo rechazo se registra con actor, acción, fecha y motivo.	CUMPLIDO	AuditoriaEventClient.java emite POST asíncrono a ms-cumplimiento y registra AUDIT_TRAIL JSON en stdout.
CA-4: Formato RFC 7807 UTF-8 Frontend muestra 'no tienes permiso para esta acción' ante 403.	CUMPLIDO	Respuesta application/problem+json;charset=UTF-8 con detail oficial. Inspección real de red en frontend.

CA-5: Mecanismo Reutilizable y Prueba de Bypass Anotación genérica y suite de pruebas de ataque/penetración.	CUMPLIDO	SecurityBypassTest.java con 7 pruebas de penetración superadas al 100%.
--	-----------------	---

Estructura de la Respuesta RFC 7807 Problem Details y Revocación JWT

Contrato RFC 7807: Cabecera Content-Type: application/problem+json;charset=UTF-8 con el payload: {"type": "https://nexusbattles.upb.edu.co/errors/forbidden", "title": "Acceso denegado", "status": 403, "detail": "No tienes permiso para esta acción", "instance": "/api/v1/admin/ban"}

Control de Revocación de Sesiones: El JWT incorpora el claim ver. Si un administrador degrada el rol de un usuario en PostgreSQL, el campo versionToken se incrementa. En la siguiente petición, el interceptor detecta la discordancia y revoca el acceso de inmediato.

3. Trazabilidad y Suite de Pruebas Automatizadas

El microservicio ms-identidad cuenta con **99 pruebas automatizadas (100% pasando, 0 fallos, 0 errores)**. A continuación se detallan las suites críticas responsables de la verificación de RBAC y Seguridad:

Clase de Prueba	Pruebas	Escenarios Validados	Resultado
SecurityBypassTest	7	Petición sin credenciales (403), rol insuficiente (403), JWT adulterado (403), JWT revocado por versión (403), admin autorizado (200), traza de auditoría, RFC 7807 UTF-8.	100% OK
RbacMatrix48CombinationsTest	2	Evaluación exhaustiva de las 48 celdas de la matriz 12x4 y verificación de Default-Deny ante valores nulos.	100% OK
RbacControllerTest	6	Endpoints REST /api/v1/rbac/roles, /matrix y /authorize. Validación de contratos OpenAPI y códigos HTTP.	100% OK
RoleAssignmentServiceTest	4	Reglas de transición de roles y restricciones de asignación de la historia HU-RBAC-003.	100% OK
EnvironmentProfileIsolationTest	3	Aislamiento estricto de perfiles: propiedades de dev nunca se filtran al entorno productivo.	100% OK
AuditoriaEventClientTest	1	Tolerancia a fallos: el CircuitBreaker aísla la falla de ms-cumplimiento sin bloquear hilos virtuales.	100% OK
Otras suites del microservicio	76	Autenticación, LoginService, RegistroService, TokenCredencial, AdminCuentas, AdminGestion.	100% OK
Total Microservicio	99	Cobertura JaCoCo superior al umbral exigido. Cero errores, cero fallos.	ÉXITO TOTAL

4. Arquitectura del Hub Integrado E2E y Usuarios de Prueba

Para evidenciar el valor del Sprint 1, el Hub (index.html) conecta de punta a punta las 4 fases del equipo: **Fase 1: Onboarding** (Cristian Chaparro · HU-AUT-001/004) → **Fase 2: Perfil** (Santiago Sanabria · HU-PER-001) → **Fase 3: Seguridad RBAC** (Andrés Núñez · HU-RBAC-001/004) → **Fase 4: Gobernanza** (Santiago & Edwin · HU-USR-003/003).

Rol Oficial	Correo Sembrado	Contraseña	Nivel RBAC	Capacidad en la Demo
Jugador	pruebajugador@test.com	MiClave123!	Nivel 1	4 / 12 acciones autorizadas. Fase 4 restringida.

Moderador	pruebamod@test.com	MiClave123!	Nivel 2	7 / 12 acciones. Suspende temporalmente.
Administrador	pruebaadmin@test.com	MiClave123!	Nivel 3	10 / 12 acciones. Desbloquea Fase 4 y baneo permanente.
Super Admin	pruebasuper@test.com	MiClave123!	Nivel 4	11 / 12 acciones. Nombra admins y asigna roles.

5. Guion Estratégico de Sustentación en Vivo (3 Minutos)

Paso 1 (Minuto 1) — Autenticación y Hub Adaptativo: Iniciar sesión en login.html con pruebajugador@test.com / MiClave123!. El sistema valida contra PostgreSQL (:5433) y abre index.html. Destacar que el Hub adapta los paneles: habilita Fases 1 a 3 y bloquea la Fase 4.

Paso 2 (Minuto 2) — HU-RBAC-001 (Matriz en Vivo y Directiva): Abrir matriz-permisos.html. Mostrar el punto de conexión verde con ms-identidad (:8089). Conmutar a Super Administrador y explicar el **11/12** por Default-Deny.

Paso 3 (Minuto 3) — HU-RBAC-004 (Verificación Server-Side): En el Hub, hacer clic en 'Comprobar 403' de una acción bloqueada. Se abre seguridad-servidor.html por deep-linking con rol y endpoint preseleccionados. Presionar 'Ejecutar Petición'. Mostrar el código **403 Forbidden RFC 7807 UTF-8** y la traza de auditoría generada.

Pregunta Difícil del Jurado	Respuesta Técnica Blindada
¿Por qué tienen 12 acciones si la Tabla 24 tenía 10?	Extendimos la matriz de forma retrocompatible para integrar ASIGNAR_ROL (Edwin) y GESTIONAR_CUENTAS (Santiago). Las 10 acciones canónicas preservan estrictamente las reglas de la Tabla 24.
¿Qué pasa si un atacante usa Postman para enviar un rol falso?	El cliente nunca es de confianza. SecurityInterceptor valida la firma criptográfica HMAC-SHA256 del Bearer JWT y su versión (ver). La petición es rechazada con 403 RFC 7807 y auditada.
¿Cómo revocan tokens de usuarios degradados?	Mediante el claim 'ver' (versión de token). Al degradar un rol o suspender una cuenta, se incrementa versionToken en PostgreSQL; los tokens anteriores quedan revocados de inmediato.